

MAPEO DETALLADO DE REQUISITOS NORMATIVOS

Encuesta Integral → Regulaciones Aplicables en España

Versión: 1.0

Fecha: Enero 2026

Aplicable a: Auditorías, Evaluaciones de Cumplimiento, Validaciones Regulatorias

MAPEO PREGUNTA-A-PREGUNTA: EPSS + NIS2 + ENS + GDPR + ISO27001

SECCIÓN 1: GOBERNANZA Y RIESGO

GR-01: Política de Gestión de Riesgos Cibernéticos

Marco Regulatorio	Requisito Específico	Número Artículo	Evidencia Encuesta	Cumplimiento Nivel
NIS2	Gestión de riesgos proporcional al riesgo planteado	Art. 21-E	GR-01 (Nivel ≥3)	Crítico
ENS	Definición de política de ciberseguridad	SD.05	GR-01 (Nivel ≥3)	Crítico
GDPR	Medidas técnicas y organizativas documentadas	Art. 32	GR-01 (Nivel ≥2)	Importante
ISO 27001	Política de seguridad información formal	A.5.1	GR-01 (Nivel ≥3)	Crítico
COBIT 2019	Gobernanza de riesgos cibernéticos	EDM, APO	GR-01 (Nivel ≥3)	Crítico

Pregunta de Validación: ¿Política documented + updated ≥ anualmente?

Criterio Paso: SÍ = Mínimo Nivel 2; Formalmente reviewada = Nivel 3+

GR-02: Marco de Conformidad Regulatoria

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Obligatorio cumplimiento de requisitos específicos	Art. 21(A-F)	GR-02 (≥ 3)	Crítico
ENS	Evaluación de aplicabilidad de controles	CP02, SD.05	GR-02 (≥ 3)	Crítico
GDPR	Mapeo de procesamiento de datos personales	Art. 30, 32	GR-02 (≥ 2)	Importante
ISO 27001	Determinación scope y aplicabilidad	4.3	GR-02 (≥ 3)	Crítico

Pregunta de Validación: ¿Gap analysis completo exists? ¿Plan de remediación documentado?

Criterio Paso: Matriz de requisitos vs controles implementados

GR-03: Responsabilidad Directiva y CISO Autonomía

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Alta dirección responsable de gestión riesgos	Art. 16(1)	GR-03 (≥ 3 : CISO reporta junta)	Crítico
ENS	Responsable Seguridad definido	CP01	GR-03 (≥ 3)	Crítico
ISO 27001	Rol de "Information Security Manager"	5.1	GR-03 (≥ 3)	Crítico
COBIT	Gobernanza integrada en estructura org.	EDM	GR-03 (≥ 4)	Importante

Pregunta de Validación: ¿CISO tiene presupuesto autonomía vs requiere aprobaciones?

Criterio Paso: Nivel 3+ = CISO authorized decisiones seguridad sin intermediarios

GR-04: Gestión de Riesgos de Terceros (Supply Chain Risk)

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Evaluación de riesgos de proveedores	Art. 21(C)	GR-04 (≥ 3)	Crítico
GDPR	Debida diligencia sobre procesadores de datos	Art. 28, 32	GR-04 (≥ 3)	Crítico
ISO 27001	Evaluación de seguridad de proveedores	A.15.1	GR-04 (≥ 3)	Crítico
ENS	Evaluación de cadena de suministro	CP04	GR-04 (≥ 2)	Importante

Pregunta de Validación: ¿Documentación formal de evaluación de terceros? ¿Monitoreo continuo o único en contrato?

Criterio Paso: Nivel 3 = Evaluación periódica (anual mínimo); Nivel 4+ = Continuo

SECCIÓN 2: GESTIÓN DE VULNERABILIDADES + EPSS

GV-01: Programa de Gestión de Vulnerabilidades - Estructura

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Gestión de vulnerabilidades documentada	Art. 21(E)	GV-01 (≥ 3)	Crítico
ENS	Control SD.05 (Gestión de Vulnerabilidades)	SD.05	GV-01 (≥ 3)	Crítico
ISO 27001	Evaluación y gestión de vulnerabilidades	A.12.6.1, A.14.2	GV-01 (≥ 3)	Crítico
NIST CSF 2.0	ID.RA-3: Identifying Risk	ID.RA	GV-01 (≥ 2)	Importante

Pregunta de Validación: ¿Programa documentado? ¿Roles/responsabilidades asignados?

Criterio Paso: Sí ambos = Mínimo Nivel 2; Formal SLAs definidos = Nivel 3

GV-02: Cobertura de Escaneo de Vulnerabilidades

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Identificación de vulnerabilidades técnicas	Art. 21(E)	GV-02 (≥ 3 : 40-70%)	Crítico
ENS	Cobertura de sistemas informáticos	SD.05	GV-02 (≥ 3 : 40-70%)	Crítico
ISO 27001	Evaluación sistemas información	A.12.6.1	GV-02 (≥ 3)	Crítico

Pregunta de Validación: ¿Qué % sistemas críticos escaneados regularmente?

Criterio Paso: >40% = Mínimo aceptable; >70% = Bueno; >90% = Excelente

GV-03: Implementación de EPSS (Exploit Prediction Scoring System)

Marco	Requisito	Art.	Evidencia	Nivel
INCIBE	Recomendación: EPSS como métrica priorización	Guía EPSS 2025	GV-03 (≥ 3)	Importante
NIS2	Priorización "proporcional a riesgo real"	Art. 21(E)	GV-03 (≥ 3 : ≥ 0.088)	Crítico
NIST CSF 2.0	Priorización basada en probabilidad	ID.RA, GOVERN	GV-03 (≥ 3)	Importante
Best Practice	Reduce esfuerzo remediación 50% + mejora coverage 8x	Industry Standard	GV-03 (≥ 3)	Estratégico

Pregunta de Validación: ¿EPSS integrado en flujo decisonal? ¿% CVEs puntuadas?

Criterio Paso: Nivel 3 = >50% CVEs con EPSS score; Nivel 4 = >90% con actualizaciones diarias

GV-04: Priorización Integrada (EPSS + CVSS + KEV + SSVc)

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Priorización multi-criterio de vulnerabilidades	Art. 21(E)	GV-04 (≥ 3)	Crítico
CISA	Utilización KEV Catalog + scoring complementario	Guidelines	GV-04 (≥ 3)	Importante
NIST CSF	Decisiones basadas en contexto organizacional	GOVERN	GV-04 (≥ 3)	Importante

Pregunta de Validación: ¿Matriz decisional documentada? ¿Automatizada o manual?

Criterio Paso: Matriz clara = Nivel 3; Automatizada en herramientas = Nivel 4

GV-05: Mean Time to Remediate (MTTR) - Vulnerabilidades Críticas

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Remediación proporcional + medida	Art. 21(E)	GV-05 (SLA ≤ 7 días)	Crítico
ENS	Control de vulnerabilidades técnicas (SD.05)	SD.05	GV-05 (SLA ≤ 30 días)	Crítico
ISO 27001	Gestión de incidentes y parches	A.16.1, A.14.2	GV-05 (SLA definido)	Importante
NIST CSF	PR.IP-4: Change detection processes	PR.IP	GV-05 (SLA defined)	Importante

Pregunta de Validación: ¿SLA formal? ¿Cumplimiento medido?

Criterio Paso: NIS2 requiere < 7 días para críticas; ENS típicamente > 30 días acceptable

GV-06: Validación Post-Remediación (Re-escaneo)

Marco	Requisito	Art.	Evidencia	Nivel
ENS	Verificación de efectividad del control	SD.05	GV-06 (≥ 3 : 70%+ validated)	Importante
ISO 27001	Evaluación de efectividad controles	8.1, 9.2	GV-06 (≥ 3)	Importante
Best Practice	Cierre de vulnerabilidad basado en validación técnica	Industry Standard	GV-06 (≥ 3)	Estratégico

Pregunta de Validación: ¿Re-escaneo formal? ¿Cerrar solo tras confirmación técnica?

Criterio Paso: >70% re-scans = Buena práctica; <50% = Riesgo de falsa seguridad

GV-07: Eficiencia Operacional de Gestión de Vulnerabilidades

Marco	Requisito	Art.	Evidencia	Nivel
Business Sustainability	Carga de trabajo manejable para equipo	General Mgmt	GV-07 (≤ 500 CVEs/mes)	Operacional
NIS2	Remediación "proporcional" implica eficiencia	Art. 21(E)	GV-07 (≤ 500 con EPSS)	Crítico

Pregunta de Validación: ¿Equipo remediación saturado o capacidad disponible?

Criterio Paso: <500 mensuales = Manejable; >5000 = Crisis

SECCIÓN 3: PRUEBAS DE PENETRACIÓN

PT-01: Cadencia de Pruebas de Penetración

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Evaluaciones externas periódicas de seguridad	Art. 21(E)	PT-01 (≥ 2 /año mínimo)	Crítico
ENS	Pruebas de penetración (AP/sector público)	CP03	PT-01 (≥ 1 /año mínimo)	Crítico
ISO 27001	Testing de controles de seguridad	A.14.2.1	PT-01 (≥ 1 /año)	Importante
NIST CSF	Continuous assessment & testing	PR.AC-6	PT-01 (≥ 2 /año)	Importante

Pregunta de Validación: ¿Pruebas formales o ad-hoc? ¿Independiente o interno?

Criterio Paso: NIS2 requiere ≥ 2 /año; ENS ≥ 1 /año mínimo

PT-02: Cobertura de Superficies de Ataque

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Evaluación completa de sistemas	Art. 21(E)	PT-02 ($> 70\%$ requerido)	Crítico
ENS	Cobertura de infraestructura + aplicaciones	CP03	PT-02 ($> 50\%$ mínimo)	Importante
ISO 27001	Evaluación sistemas información en scope	4.3, A.14	PT-02 (100% scope)	Crítico

Pregunta de Validación: ¿Qué tipo sistemas NO se testean? ¿Por qué?

Criterio Paso: $> 70\%$ = NIS2 compliant; $< 40\%$ = Riesgos significativos

PT-03: Metodología y Documentación

Marco	Requisito	Art.	Evidencia	Nivel
ENS	Metodología reconocida para pruebas	CP03	PT-03 (PTES, OWASP)	Importante
ISO 27001	Evidencia de testing metodológico	A.14.2	PT-03 (Documented)	Importante
Auditoría	Capacidad replicación / auditoría de hallazgos	General	PT-03 (Reproducible)	Estratégico

Pregunta de Validación: ¿Metodología estandarizada? ¿Reproducible por auditor?

Criterio Paso: Sí ambos = Nivel 3+

PT-04: Validez de Hallazgos (False Positives)

Marco	Requisito	Art.	Evidencia	Nivel
Auditoría	Hallazgos válidos y confirmables	General	PT-04 (>80% válidos)	Operacional
Best Practice	Precisión de diagnóstico de vulnerabilidades	Industry Std	PT-04 (>85% válidos)	Operacional

Pregunta de Validación: ¿Qué % hallazgos fueron confirmados vs false positives?

Criterio Paso: >75% = Aceptable; >85% = Bueno

PT-05 & PT-06: Remediación y Re-pruebas

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Remediación de hallazgos críticos	Art. 21(E) implicit	PT-05 (SLA <30 días)	Crítico
ENS	Cierre de vulnerabilidades identificadas	CP03	PT-05 (SLA <60 días)	Importante
ISO 27001	Verificación de efectividad remediación	8.1	PT-06 (≥80% re-tested)	Importante

Pregunta de Validación: ¿SLA formal para cierre? ¿Re-pruebas confirmadas?

Criterio Paso: Ambos = Nivel 4; Solo SLA = Nivel 3

SECCIÓN 4: MONITOREO DE SEGURIDAD (SIEM)

SI-01: Implementación y Cobertura de SIEM

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Monitoreo de seguridad en tiempo real	Art. 21(C)	SI-01 ($\geq 30\%$ cobertura min)	Crítico
ENS	Monitoreo eventos de seguridad	SF.01	SI-01 ($\geq 30\%$ cobertura)	Crítico
GDPR	Registro de eventos de acceso	Art. 32, recital 83	SI-01 ($\geq 50\%$ systems)	Importante
ISO 27001	Logging y monitoreo	A.12.4, A.16	SI-01 ($\geq 50\%$ systems)	Importante

Pregunta de Validación: ¿SIEM centralizado? ¿Qué % infraestructura conectada?

Criterio Paso: $>30\%$ = Mínimo; $>70\%$ = Bueno

SI-02: Capacidad de Detección (Detection Rules)

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Detección de intentos acceso no autorizado	Art. 21(C)	SI-02 (>200 rules)	Crítico
MITRE ATT&CK	Cobertura de técnicas atacantes conocidas	Framework	SI-02 (>300 rules)	Estratégico
ISO 27001	Monitoreo de accesos y eventos	A.16.1	SI-02 (>100 rules)	Importante

Pregunta de Validación: ¿Cuántas reglas activas? ¿Coverage de MITRE tactics?

Criterio Paso: <100 = Muy básico; 200-500 = Bueno; >1000 = Excelente

SI-03: Mean Time to Detect (MTTD)

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Detección rápida de incidentes	Art. 19(1)	SI-03 (<24 horas)	Crítico
ENS	Tiempo a detección de ataques	SF.01	SI-03 (<7 días típico)	Importante
GDPR	Descubrimiento rápido de breaches	Art. 33 implicit	SI-03 (<24 horas ideal)	Importante

Pregunta de Validación: ¿Cómo se mide MTTD? ¿Se documentan tiempos?

Criterio Paso: <24 horas = NIS2 compliant; <7 días = ENS acceptable

SI-04: Tasa de Falsos Positivos

Marco	Requisito	Art.	Evidencia	Nivel
Operacional	Gestión eficiente de alertas	General Mgmt	SI-04 (<40% FP)	Operacional
Burnout Prevention	Prevención de fatiga de alertas en equipo	General Mgmt	SI-04 (<60% FP)	Estratégico

Pregunta de Validación: ¿Qué % alertas requieren investigación vs auto-resolved?

Criterio Paso: <40% FP = Bien tuneado; 40-60% = Acceptable; >80% = Problema

SI-05: Respuesta Automatizada (SOAR Integration)

Marco	Requisito	Art.	Evidencia	Nivel
NIST CSF	Automatización de respuesta	RS.CO-2	SI-05 (>20% automated)	Importante
Eficiencia Operacional	Reducción de MTTR	General Mgmt	SI-05 (>30% automated)	Estratégico

Pregunta de Validación: ¿Qué incidentes se resuelven automáticamente?

Criterio Paso: 0% = Manual investigation only; >20% = Inicio de automatización

SI-06: Retención de Logs y Cumplimiento

Marco	Requisito	Art.	Evidencia	Nivel
GDPR	Retención de datos mínimo 1-3 años	Art. 5(1)(e), recital 39	SI-06 (≥1 año)	Crítico
NIS2	Retención logs suficiente para investigación	Art. 19 implicit	SI-06 (≥1 año)	Crítico
ENS	Retención de eventos seguridad	SF.01	SI-06 (≥90 días mín)	Importante
PCI-DSS	Retención mínima 1 año (3 meses online)	10.7	SI-06 (≥1 año)	Crítico (si aplica)

Pregunta de Validación: ¿Política formal de retención? ¿Alineada a requisitos?

Criterio Paso: ≥1 año = GDPR/NIS2 compliant; <90 días = Riesgo legal

SECCIÓN 5: RESPUESTA A INCIDENTES

RI-01: Plan de Respuesta a Incidentes

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Plan de respuesta a incidentes	Art. 17(1)(b)	RI-01 ($\geq$ Nivel 3)	Crítico
ENS	Plan de continuidad de negocio	CP05	RI-01 ($\geq$ Nivel 3)	Importante
GDPR	Procedimientos de respuesta a breaches	Art. 32 implicit	RI-01 ($\geq$ Nivel 2)	Importante
ISO 27001	Plan de respuesta a incidentes	A.16	RI-01 ($\geq$ Nivel 3)	Crítico
NIST CSF	Incident Response Planning	RS	RI-01 ($\geq$ Nivel 3)	Importante

Pregunta de Validación: ¿Plan documentado? ¿Testeado en último año?

Criterio Paso: Documentado = Nivel 2; Testeado = Nivel 3+

RI-02: Roles y Responsabilidades

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Designación de Autoridad Competente + Roles IR	Art. 16(1)	RI-02 ($\geq$ Nivel 3)	Crítico
ENS	Responsables de incidentes identificados	CP05	RI-02 ($\geq$ Nivel 3)	Importante
ISO 27001	Designación de Incident Response Team	A.16.1	RI-02 ($\geq$ Nivel 3)	Importante

Pregunta de Validación: ¿Matriz RACI documentada? ¿Comunicada a todos?

Criterio Paso: Documentada + Comunicada = Nivel 3+

RI-03: Escalación y Comunicación a Reguladores

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Notificación a autoridades <24 horas	Art. 19(1)	RI-03 (<24 horas SLA)	Crítico
GDPR	Notificación a autoridades <72 horas	Art. 33(1)	RI-03 (<72 horas SLA)	Crítico
ENS	Notificación según procedimiento	CP05	RI-03 (SLA defined)	Importante

Pregunta de Validación: ¿SLA formal? ¿Procedimiento notificación a autoridades?

Criterio Paso: NIS2 requiere <24h; GDPR <72h; ambos son críticos

RI-04: Capacidad 24/7

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Disponibilidad continua de respuesta	Art. 17(1) implicit	RI-04 ($\geq$ Nivel 3: 24/7)	Importante
Best Practice	Capacidad respuesta fuera horario	Industry Std	RI-04 ($\geq$ Nivel 4: SOC 24/7)	Estratégico

Pregunta de Validación: ¿On-call formalizado? ¿SLA de respuesta?

Criterio Paso: On-call $\geq$ 2 personas = Nivel 3; SOC dedicado = Nivel 4

RI-05: Investigación Forense

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Capacidad investigación de incidentes	Art. 19(1) implicit	RI-05 ($\geq$ Nivel 3)	Importante
GDPR	Investigación de breaches	Art. 33-34	RI-05 ($\geq$ Nivel 2)	Importante
ISO 27001	Análisis post-incidente	A.16.1	RI-05 ($\geq$ Nivel 3)	Importante

Pregunta de Validación: ¿Herramientas forenses disponibles? ¿Personal capacitado?

Criterio Paso: Herramientas + formación = Nivel 3; Automatización = Nivel 4

RI-06: Post-Incident Review (PIR)

Marco	Requisito	Art.	Evidencia	Nivel
ISO 27001	Análisis y lecciones aprendidas	A.16.1	RI-06 ($\geq 80\%$ incidentes)	Importante
Best Practice	Cierre de incidentes con lecciones	Industry Std	RI-06 (100% incidentes)	Estratégico
ENS	Documentación de incidentes	CP05	RI-06 ($\geq 70\%$ incidentes)	Importante

Pregunta de Validación: ¿PIR formal para qué % incidentes?

Criterio Paso: 70%+ incidentes = Buena práctica; 100% = Excelente

SECCIÓN 6: CAPACITACIÓN Y CONCIENCIA DE SEGURIDAD

CC-01: Programa de Capacitación

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Programa de concienciación en ciberseguridad	Art. 21(D)	CC-01 ($\geq$ Nivel 3)	Crítico
GDPR	Capacitación en protección datos	Art. 32(4)	CC-01 ($\geq$ Nivel 2)	Crítico
ENS	Capacitación en seguridad	SP.01	CC-01 ($\geq$ Nivel 2)	Importante
ISO 27001	Conciencia de seguridad para empleados	A.6.2	CC-01 ($\geq$ Nivel 3)	Importante
NIST CSF	Educación y conciencia de seguridad	PR.AT	CC-01 ($\geq$ Nivel 2)	Importante

Pregunta de Validación: ¿Programa formal + documentado? ¿Multi-canal?

Criterio Paso: Documentado = Nivel 2; Temático multi-canal = Nivel 3

CC-02: Tasa de Cumplimiento

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Todos empleados deben recibir conciencia	Art. 21(D)	CC-02 ($>85\%$ objetivo)	Crítico
GDPR	Registro de capacitación completada	Art. 32	CC-02 ($>80\%$ actual)	Importante

Pregunta de Validación: ¿% empleados completaron capacitación obligatoria?

Criterio Paso: 70%+ = Aceptable; 85%+ = Bueno; 95%+ = Excelente

CC-03 & CC-04: Phishing Simulaciones + Reporte

Marco	Requisito	Art.	Evidencia	Nivel
NIS2	Programa de conciencia práctica	Art. 21(D)	CC-03 (≥mensual)	Importante
Best Practice	Simular amenazas reales (phishing)	Industry Std	CC-03 (≥mensual)	Estratégico
Behavioral Change	Empleados reportan phishing	General Best Practice	CC-04 (>20% objetivo)	Estratégico

Pregunta de Validación: ¿Qué % empleados hacen clic phishing? ¿Qué % lo reportan?

Criterio Paso: Click rate <15% + Report rate >20% = Programa efectivo

CC-05: Capacitación Especializada por Rol

Marco	Requisito	Art.	Evidencia	Nivel
ENS	Especialización según rol	SP.01	CC-05 (≥Nivel 3)	Importante
ISO 27001	Formación según responsabilidades	A.6.2	CC-05 (≥Nivel 3)	Importante
NIST CSF	Role-based education	PR.AT-2	CC-05 (≥Nivel 2)	Importante

Pregunta de Validación: ¿Existe capacitación diferenciada por rol (devs, admins, exec)?

Criterio Paso: Sí, documentada = Nivel 3+

CC-06 & CC-07: Efectividad + Comunicación

Marco	Requisito	Art.	Evidencia	Nivel
Best Practice	Medición de cambio de comportamiento	Industry Std	CC-06 (≥Nivel 3)	Estratégico
NIS2	Comunicación de amenazas / incidentes	Art. 21(D)	CC-07 (≥mensual)	Importante
Continuous Improvement	Feedback en programa capacitación	General Mgmt	CC-06 (≥Nivel 4)	Estratégico

Pregunta de Validación: ¿Cómo mides si la capacitación cambió comportamiento?

Criterio Paso: Pre/post-test = Nivel 3; Métricas conductuales = Nivel 4+

TABLA DE SÍNTESIS: NIVEL MÍNIMO POR REGULACIÓN

NIS2 (Sector Crítico)

Pregunta	NIS2 Requisito	Nivel Mínimo	Prioridad
GR-01	Art. 21(E) Gobernanza	3	Crítica
GR-02	Art. 21(A-F) Cumplimiento	3	Crítica
GR-03	Art. 16(1) Dirección	3	Crítica
GV-01	Art. 21(E) Gestión Vulns	3	Crítica
GV-03	Art. 21(E) Priorización	3	Crítica
PT-01	Art. 21(E) Pruebas	2	Importante
SI-01	Art. 21(C) Monitoreo	3	Crítica
RI-01	Art. 17(1)(b) Plan IR	3	Crítica
RI-03	Art. 19(1) Notificación <24h	3	Crítica
CC-01	Art. 21(D) Conciencia	3	Crítica

NIS2 Mínimo IGM Recomendado: 3.5+

GDPR (Aplicable a Todas Organizaciones con Datos EU)

Pregunta	GDPR Artículo	Nivel Mínimo	Prioridad
GR-01	Art. 32 Seguridad	2	Importante
GV-02	Art. 32 Medidas técnicas	2	Importante
SI-01	Art. 32 Logging	2	Importante
SI-06	Art. 5(1)(e) Retención	3	Crítica
RI-01	Art. 32 Breach response	2	Importante
RI-03	Art. 33 Notificación <72h	3	Crítica
CC-01	Art. 32(4) Capacitación	2	Importante

GDPR Mínimo IGM Recomendado: 2.5+

ENS (Sector Público España)

Pregunta	Control ENS	Nivel Mínimo	Prioridad
GR-01	CP01/02 Gobernanza	2	Importante
GV-01	SD.05 Gestión Vulns	2	Importante
PT-01	CP03 Pruebas	1	Importante
SI-01	SF.01 Monitoreo	2	Importante
RI-01	CP05 Plan IR	2	Importante
CC-01	SP.01 Conciencia	2	Importante

ENS Mínimo IGM Recomendado: 2.0+

CONCLUSIÓN: MATRIZ DE CUMPLIMIENTO

Para **Organizaciones España 2026:**

Sector	Regulación Aplicable	IGM Mínimo	Periodo Cumplimiento
Sector Público General	ENS + GDPR	2.5	Permanente
Sector Crítico (NIS2)	NIS2 + GDPR + ENS	3.8	Septiembre 2025 (pasado)
Banca/Finanzas	NIS2 + PCI-DSS + GDPR	4.0+	Septiembre 2025 (pasado)
Salud	NIS2 + GDPR + ISO 27001	3.5+	Septiembre 2025 (pasado)
Energía/Crítica	NIS2 + GDPR + TISAX	4.0+	Septiembre 2025 (pasado)
PME/Privada General	GDPR (mínimo)	2.0	Permanente

Recomendación: Todas organizaciones en España deberían alcanzar mínimo IGM 2.5 (GDPR) por 2026.

*Mapeo desarrollado por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad
Enero 2026*